Phát hiện Tấn công DDoS bằng Học máy: Pipeline FAMS + Leave-One-Group-Out trên CIC-DDoS 2019

Báo cáo Học máy Ứng dụng

Nhóm nghiên cứu

Học viện Kỹ thuật

Tháng 3, 2026

Nội dung trình bày

1. Giới thiệu
2. Pipeline hai giai đoạn
3. Phase 1 — Lựa chọn đặc trưng FAMS
4. Phase 2 — Thiết kế Leave-One-Group-Out
5. Kết quả thực nghiệm
6. Thảo luận
7. Kết luận

Tấn công DDoS là gì?

Định nghĩa

Tấn công DDoS (Distributed Denial of Service) điều phối **nhiều nguồn phân tán** (botnet) để làm gián đoạn **tính sẵn sàng** của dịch vụ.

Hậu quả

- Thiệt hại tài chính trực tiếp
- Mất uy tín tổ chức
- Gián đoạn hạ tầng thiết yếu

Ba nhóm tấn công (CIC-DDoS 2019)

G1 Reflection/Application
DNS, LDAP, MSSQL, NetBIOS, SNMP, Portmap

G2 Reflection/Volume
NTP, TFTP

G3 Exploitation/Flooding
Syn, UDP, UDPLag, WebDDoS

Thách thức phát hiện DDoS bằng học máy

1. **Đa dạng loại tấn công** — volumetric, protocol, application-layer
   Mỗi nhóm có phân phối lưu lượng rất khác nhau
2. **Khả năng tổng quát hóa** — mô hình cần phát hiện tấn công *mới chưa thấy*
   Câu hỏi trọng tâm của báo cáo này
3. **Mất cân bằng lớp** — lưu lượng bình thường $\gg$ lưu lượng tấn công
   Dùng F2-score thay vì Accuracy
4. **Lựa chọn đặc trưng** — 70+ đặc trưng, nhiều đặc trưng dư thừa
   Giải quyết bằng khung FAMS (Phase 1)

Câu hỏi nghiên cứu

1. Tập đặc trưng FAMS từ bộ Kaggle có **hiệu quả trên CIC-DDoS 2019**?
2. Mô hình huấn luyện trên một nhóm có **tổng quát hóa tốt** sang nhóm chưa thấy?
3. Trong KNN, RF, XGB — **mô hình nào tổng quát hóa tốt nhất** theo LOGO?

$\Rightarrow$ *Trả lời qua thiết kế **Leave-One-Group-Out (LOGO)** trên CIC-DDoS 2019*

Tổng quan pipeline

Phase 1 — Lựa chọn đặc trưng

Kaggle DDoS
(CIC 2016/17/18)

$\Downarrow$

FAMS
(5 phương pháp + bỏ phiếu)

$\Downarrow$

18 đặc trưng
(votes ≥ 3)

$\Rightarrow$

Phase 2 — Huấn luyện LOGO

CIC-DDoS 2019
(17 Parquet)

$\Downarrow$

LOGO Training
(KNN / RF / XGB)

$\Downarrow$

Đánh giá
F2, Gap, FNR

Khung FAMS: bỏ phiếu đa phương pháp

5 phương pháp lựa chọn đặc trưng:

- **Filter:** Variance Threshold, Mutual Information
- **Wrapper:** RFE (Recursive Feature Elimination)
- **Embedded:** Lasso L1, RF Feature Importance

Cơ chế bỏ phiếu:

$$\mathcal{F}_{opt} = \left\{ f_j \;\middle|\; \sum_{k=1}^{5} \mathbf{1}[f_j \in \text{top-25}_k] \geq \tau \right\}$$

Hai ngưỡng so sánh

Ngưỡng τ	#Đặc trưng	F2 TB
≥ 3	**18**	**0,9956**
> 3	6	0,9840

Lựa chọn

18 đặc trưng (votes ≥ 3) được dùng cho Phase 2
(giảm 75% số chiều so với 70+ đặc trưng gốc)

Phase 1: Kết quả đánh giá trên Kaggle

Bảng: Hiệu năng phân loại theo ngưỡng bỏ phiếu FAMS

Ngưỡng	Mô hình	Acc	Prec	Recall	F2	FNR
≥ 3 (18 ft.)	KNN	0,993	0,992	0,994	0,993	0,006
	RF	0,997	0,998	0,997	0,997	0,003
	XGB	0,997	0,998	0,996	0,997	0,004
> 3 (6 ft.)	KNN	0,983	0,978	0,987	0,985	0,013
	RF	0,982	0,981	0,981	0,981	0,019
	XGB	0,983	0,977	0,988	0,986	0,012

FNR của RF giảm từ **0,0188** xuống **0,0034** khi tăng từ 6 lên 18 đặc trưng

18 đặc trưng FAMS được chọn

1. Fwd Packet Length Mean
2. Fwd Packet Length Max
3. Fwd Packets Length Total
4. Fwd Seg Size Min
5. Flow IAT Min
6. Fwd Packet Length Std
7. Subflow Bwd Bytes
8. Packet Length Max
9. Init Bwd Win Bytes
10. Packet Length Std
11. Subflow Fwd Bytes
12. Fwd Header Length
13. Flow Packets/s
14. Bwd Packet Length Max
15. Bwd Packets Length Total
16. Avg Fwd Segment Size
17. Subflow Fwd Packets
18. Bwd Packet Length Std

CIC-DDoS 2019: Dữ liệu và phân nhóm

Bộ dữ liệu

- 17 file Parquet, 388.505 dòng (sau tiền xử lý)
- Đặc trưng: chỉ dùng **18 đặc trưng FAMS**
- Chuẩn hóa: **RobustScaler** (fit trên train)

Phân nhóm tấn công

G1	Refl/App	22.839 mẫu
G2	Refl/Vol	200.705 mẫu
G3	Exploit	77.471 mẫu
Benign		87.490 mẫu

Thiết kế LOGO

- **Exp 1:** Train G1 → Test G2+G3
  Train: 84.082 / Test: 304.423
- **Exp 2:** Train G2 → Test G1+G3
  Train: 261.948 / Test: 126.557
- **Exp 3:** Train G3 → Test G1+G2
  Train: 138.714 / Test: 249.791

Benign 70% cố định cho train, 30% cho test — dùng chung ba Exp

Quy trình huấn luyện và tối ưu siêu tham số

1. **Optuna TPE** — 30 trials, mục tiêu tối đa **F2 (5-fold StratifiedKFold)**
   Không gian tìm kiếm: k, metric (KNN); n_estimators, depth, features (RF/XGB)
2. **Xử lý mất cân bằng lớp**
   - RF: `class_weight='balanced'`
   - XGB: `scale_pos_weight`
   - KNN: không hỗ trợ tường minh
3. **Huấn luyện lại** trên toàn bộ train sau khi tìm được best params
4. **Đánh giá** trên tập test (nhóm chưa thấy trong huấn luyện)

Chỉ số đánh giá chính

F2-score, F1, Recall, FNR, AUC, **Gap** = CV F2 − Test F2

Kết quả tổng hợp: Leave-One-Group-Out

Thí nghiệm	Mô hình	CV F2	Test F2	Recall	FNR	Gap
Exp 1 (G1→G2+G3)	KNN	0,9952	**0,603**	0,548	0,452	+0,39
	RF	0,9972	**0,833**	0,800	0,200	+0,16
	XGB	0,9976	0,776	0,735	0,265	+0,22
Exp 2 (G2→G1+G3)	KNN	0,9991	**0,622**	0,568	0,432	+0,38
	RF	0,9995	**0,620**	0,566	0,434	+0,38
	XGB	0,9993	**0,622**	0,568	0,432	+0,38
Exp 3 (G3→G1+G2)	KNN	0,9937	0,917	0,899	0,101	+0,08
	RF	**0,9981**	**0,985**	**0,981**	**0,019**	**+0,01**
	XGB	0,9978	0,902	0,881	0,119	+0,10

RF Exp 3: Test F2 = 0,985; Gap = +0,013; FNR = **1,9%**

Phân tích: Exp 1 — Huấn luyện trên G1

Bối cảnh

- G1 nhỏ nhất: 22.839 mẫu tấn công
- Đặc trưng đồng nhất: phản xạ giao thức ứng dụng (DNS/LDAP/MSSQL)

Giải thích

Mô hình học "nhận dạng giao thức cụ thể" thay vì pattern DDoS tổng quát. RF tổng quát hóa tốt hơn nhờ **bagging** đa dạng hóa biên quyết định.

Kết quả

- KNN: Test F2 = **0,60**, Gap +0,39
- RF: Test F2 = **0,83**, Gap +0,16
- XGB: Test F2 = 0,78, Gap +0,22

Phân tích: Exp 2 — Huấn luyện trên G2

Bối cảnh

- G2 lớn nhất: 200.705 mẫu
- Nhưng **rất đồng nhất**: chỉ NTP (UDP/123) và TFTP (UDP/69)

Kết quả đáng chú ý

- Cả 3 mô hình: Test F2 $\approx$ **0,62**
- Gap đồng loạt +0,38
- **Lợi thế bagging của RF biến mất!**

Bài học quan trọng

*Kích thước tập train lớn **không đảm bảo** tổng quát hóa tốt nếu tập đó **thiếu đa dạng** về loại lưu lượng.*

Khi toàn bộ 200k mẫu phân bố trong vùng đặc trưng hẹp (NTP/TFTP), mọi cây trong RF đều học cùng biên quyết định hẹp.

Phân tích: Exp 3 — Huấn luyện trên G3 (*Best case*)

Bối cảnh

- G3 đa dạng: Syn, UDP, UDPLag, WebDDoS
- Bao gồm cả tấn công **thể tích** lẫn **tầng ứng dụng**
- Tương đồng với dữ liệu Kaggle (Phase 1)

Kết quả xuất sắc

- RF: Test F2 = **0,985**, Gap = **+0,013**
- FNR = **1,89%** — phát hiện hơn 98% tấn công từ G1+G2

Lý giải

Đặc trưng học từ G3 **đa dạng về kích thước gói, tốc độ luồng, tỷ lệ forward/backward** → tổng quát hóa tốt sang G1+G2.

FAMS Phase 1 cũng dùng Kaggle chứa UDP/Syn Flood → tập 18 đặc trưng phù hợp với G3.

Hiệu quả tính toán

Bảng: Thời gian huấn luyện và suy luận (KNN dùng `algorithm=ball_tree`)

Thí nghiệm	Mô hình	Train size	Train (s)	Infer (ms/mẫu)	Test F2
Exp 1 (84k)	KNN	84.082	0,27	0,3148	0,603
	RF	84.082	5,85	0,0161	0,833
	XGB	84.082	1,97	**0,0034**	0,776
Exp 2 (262k)	KNN	261.948	1,51	0,1760	0,622
	RF	261.948	1,18	**0,0027**	0,620
	XGB	261.948	13,11	0,0082	0,622
Exp 3 (139k)	KNN	138.714	0,08	0,6512	0,917
	RF	138.714	4,94	0,0106	**0,985**
	XGB	138.714	4,28	**0,0011**	0,902

RF và XGB: thời gian suy luận $<$ 0,02 ms/mẫu — phù hợp phát hiện thời gian thực

So sánh ba mô hình

Random Forest

Tốt nhất tổng quát

Test F2 cao nhất ở Exp 1 (0,83) và Exp 3 (0,985).
Gap nhỏ nhất ở Exp 3 (+0,013).
Bagging giảm phương sai hiệu quả.

XGBoost

AUC cao

AUC = 0,99 ở Exp 1, Exp 3.
Nhưng Gap lớn hơn RF ở Exp 3 (+0,096 vs +0,013).
Học pattern phức tạp, dễ overfit.

KNN

Phụ thuộc phân phối

Test F2 thấp nhất ở Exp 1, 2 ($\approx$ 0,61).
Cải thiện tốt khi train/test tương đồng (Exp 3: 0,92).
Suy luận chậm hơn RF/XGB.

Trả lời câu hỏi nghiên cứu

Q1: FAMS Kaggle có hiệu quả trên CIC-DDoS 2019?

Có, nhưng không đồng đều. Test F2 = 0,985 (RF, Exp 3) khi nhóm train tương đồng với Kaggle. Giảm rõ rệt (0,62–0,83) khi nhóm train là Reflection.

Q2: Tổng quát hóa sang nhóm chưa thấy?

Phụ thuộc tính đa dạng của nhóm train. G3 (đa dạng) $\rightarrow$ Gap $\approx$ 0,01. G1, G2 (đơn điệu giao thức) $\rightarrow$ Gap = 0,16–0,39.

Q3: Mô hình nào tốt nhất theo LOGO?

Random Forest — nhất quán Test F2 và Gap tốt nhất qua cả ba thí nghiệm.

Phát hiện quan trọng: Đa dạng > Kích thước

Tính đa dạng của dữ liệu huấn luyện
— không phải kích thước —
là yếu tố quyết định khả năng tổng quát hóa

Bằng chứng

G2 (200k mẫu, nhưng chỉ NTP+TFTP):
Test F2 = **0,62**

G3 (78k mẫu, nhưng Syn+UDP+WebDDoS):
Test F2 = **0,985**

Ý nghĩa thực tiễn

Chiến lược thu thập dữ liệu huấn luyện nên ưu tiên **đa dạng loại tấn công** hơn **số lượng mẫu thuần túy**.

Kết luận

Đóng góp chính

1. **Lựa chọn đặc trưng FAMS đa phương pháp:** 18 đặc trưng (votes ≥ 3) đạt F2 TB $= 0{,}9956$ trên Kaggle; giảm 75% số chiều.
2. **Đánh giá LOGO trên CIC-DDoS 2019:**
   - RF Exp 3: Test F2 $= 0{,}985$, FNR $= 1{,}89\%$, Gap ≈ 0 — không overfit nhóm
   - Exp 1&2: Gap lớn (0,16–0,39) do đặc trưng giao thức đặc thù không chuyển giao tốt
   - Random Forest nhất quán tốt nhất trong ba mô hình

Phát hiện cốt lõi

Đa dạng dữ liệu huấn luyện $>$ **Kích thước** — quyết định khả năng tổng quát hóa

Hạn chế và hướng phát triển

Hạn chế

- Dữ liệu phòng thí nghiệm (chưa có TLS, IPv6)
- Bất đối xứng tổng quát hóa: tốt từ G3 sang G1+G2, kém chiều ngược lại
- Mô hình tĩnh, chưa xử lý *concept drift*
- WebDDoS chỉ 51 mẫu trong G3

Hướng phát triển

- Giải quyết bất đối xứng tổng quát hóa (transfer learning)
- Huấn luyện đa nhóm với tỷ lệ mẫu tối ưu
- Đánh giá trên dữ liệu thực (TLS, cloud)
- Online Learning / periodic retraining
- SHAP để giải thích feature importance

Cảm ơn!

Code: `phase1_feature_selection.ipynb`
`phase2_model_training.ipynb`

Câu hỏi và thảo luận?

Siêu tham số tốt nhất (Optuna TPE, 30 trials)

Exp	Mô hình	Siêu tham số tốt nhất
Exp 1	KNN	`n_neighbors=3, weights=distance`
	RF	`n_estimators=100, max_depth=19, min_samples_split=2, max_features=log2`
	XGB	`n_estimators=500, max_depth=7, lr=0.035, subsample=0.785`
Exp 2	KNN	`n_neighbors=5, weights=distance`
	RF	`n_estimators=150, max_depth=18, min_samples_split=2, max_features=log2`
	XGB	`n_estimators=450, max_depth=7, lr=0.094, subsample=0.999`
Exp 3	KNN	`n_neighbors=3, weights=distance`

Fβ-score: tại sao chọn F2?

$$F_\beta = (1+\beta^2)\,\frac{\text{Precision} \times \text{Recall}}{\beta^2 \cdot \text{Precision} + \text{Recall}}$$

- $\beta = 1$ (F1): cân bằng Precision và Recall
- $\beta = 2$ (F2): **ưu tiên Recall gấp đôi Precision**

Lý do chọn F2 trong phát hiện DDoS

Bỏ sót tấn công (False Negative, FNR cao) $\rightarrow$ hậu quả nghiêm trọng hơn báo động nhầm (False Positive).
F2 làm mục tiêu Optuna $\rightarrow$ khuyến khích Recall cao.

RobustScaler: tại sao không dùng StandardScaler?

$$x_{\text{RobustScaler}} = \frac{x - Q_2(x)}{Q_3(x) - Q_1(x)}$$

StandardScaler

Dùng mean và std $\rightarrow$ **nhạy với ngoại lai**
Lưu lượng burst traffic có thể làm lệch mean đáng kể

RobustScaler

Dùng trung vị (Q_2) và IQR ($Q_3 - Q_1$) $\rightarrow$ **bền với ngoại lai**
Phù hợp dữ liệu lưu lượng mạng

Quan trọng

Scaler được *fit* chỉ trên tập train $\rightarrow$ transform cả train và test
$\Rightarrow$ tránh data leakage